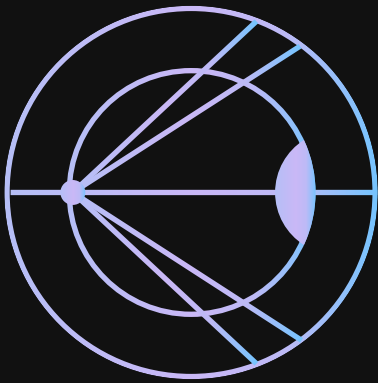




FINAL REPORT

Audit Contest

for **OxMarkets**

PREPARED BY

HackenProof

AUDIT DURATION

04.06-08.07.2026

REPORT CREATED

31.07.2026

AUDIT TYPE

Solidity

TABLE OF CONTENTS

Introduction	3
Audit summary	4
Findings list	4-8
About project	9

INTRODUCTION

HackenProof Audit is your solution to maximize cybersecurity through the involvement of the industry's most skilled and experienced community security researchers.

Name	OxMarkets
Website	https://www.0xmarkets.io/
Type	Audit Contest
Date	04.06-08.07.2026
Changelog	31.07.2026 - Final Report
Scope	OxMarkets: • https://github.com/hackenproof-public/OxMarkets_contract
Approved by	HackenProof team

AUDIT SUMMARY

54

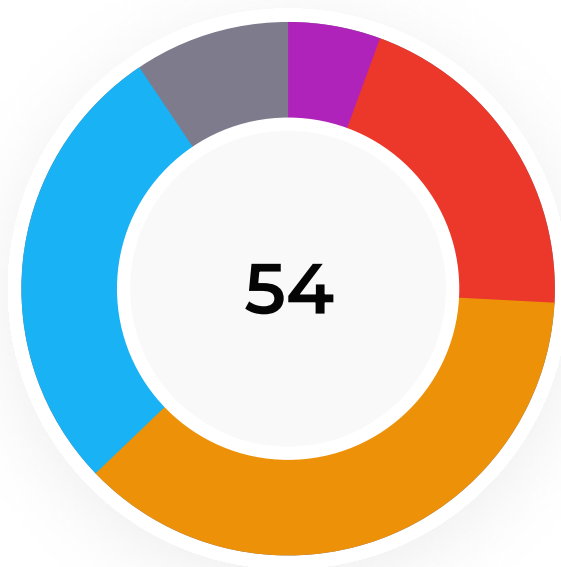
Total Findings

49

Resolved

5

Informative



• Critical	3
• High	11
• Medium	20
• Low	15
• None	5

FINDINGS LIST

• CRITICAL

	ZEROMARK-174 <u>Funding fee claims can create bad debt and freeze unrelated collateral</u>	Resolved
	ZEROMARK-233 <u>Insolvency socialization allows adversarial account pair to extract pool funds via matched liquidation</u>	Resolved
	ZEROMARK-872 <u>Gelato relay updateOrder can resurrect canceled orders and withdraw order collateral twice</u>	Resolved

• HIGH

	ZEROMARK-8 <u>Successful request execution omits execution-fee payout, stranding gasless residual WNT in OxMarkets vaults</u>	Resolved
	ZEROMARK-44 <u>Removed execution-fee cap lets a malicious subaccount steal the account's WNT</u>	Resolved

	ZEROMARK-54 <u>Insurance fund drawdown trigger uses absolute pool value against a stale snapshot, letting a no-loss LP withdrawal drain (and capture) the entire insurance reserve</u>	Resolved
	ZEROMARK-62 <u>Leverage ladder is ignored by dynamic MMR liquidation checks</u>	Resolved
	ZEROMARK-182 <u>Zero-size MarketIncrease orders crystallize borrow fees while skipping the max-leverage and min-collateral gate in `IncreasePositionUtils.increasePosition`, letting positions ride past the liquidation</u>	Resolved
	ZEROMARK-266 <u>Post-loss deposits capture insurance intended for existing LPs</u>	Resolved
	ZEROMARK-352 <u>Malicious subaccount can drain WNT auto top-up by charging an execution fee it did not fund</u>	Resolved
	ZEROMARK-483 <u>Fork's getNextOpenInterestParams reverts instead of upstream's clamp-to-0 → sole-side positions in single-token markets can never close or be liquidated (permanent freeze + liquidation DoS/insolvency)</u>	Resolved
	ZEROMARK-545 <u>PythLazerFeedProvider: inverted (FX) feed multiplier is 10^{12} too small → FX perp markets unusable, traders lose ~100% of positions under ~\$6,666 (config live on-chain)</u>	Resolved
	ZEROMARK-684 <u>A Config Keeper Can Flip Any Oracle Price Upside-Down Instantly, Skipping the 1-Day Timelock</u>	Resolved
	ZEROMARK-846 <u>Authorized subaccounts can siphon main-account collateral through unrestricted `uiFeeReceiver`</u>	Resolved

• MEDIUM

	ZEROMARK-14 <u>Permanently frozen protocol fees — veAlpha/treasury/buyback/validator fee shares have no claim entrypoint</u>	Resolved
	ZEROMARK-33 <u>`Config.setPythLazerFeed()` writes Chainlink Data Stream keys instead of Pyth Lazer keys, leaving tokens configured through the setter unpriceable</u>	Resolved
	ZEROMARK-52 <u>`min_leverage` lower bound is enforced on decreases, collateral top-ups, and ADL — trapping de-risking and degrading the ADL safety valve</u>	Resolved
	ZEROMARK-73 <u>Baseline-swap funding charged 2x in single-token markets: baselineSwapUsd missing / divisor in MarketUtils.getNextFundingAmountPerSize</u>	Resolved

	ZEROMARK-77 <u>`updateOrder` Fails to Invert Prices on `reversed` Markets — Causes Wrong Execution Price or Permanent Order DoS</u>	Resolved
	ZEROMARK-81 <u>Insurance fund deposit keys on `collateralToken` but injection reads `pnlToken` bucket — LP drawdown protection permanently fails for long positions with stablecoin collateral</u>	Resolved
	ZEROMARK-93 <u>InsuranceFundUtils.attemptInjectPool missing zero-guard on triggerFactor — uninitialized markets inject on any drawdown, depleting reserves before extreme events they are designed to cover</u>	Resolved
	ZEROMARK-97 <u>Secondary output token fee payments bypass configured OxMarkets fee receivers and are credited back to the pool</u>	Resolved
	ZEROMARK-127 <u>Permissionless getOraclePrice drains the price provider's ETH fee balance and freezes the oracle</u>	Resolved
	ZEROMARK-131 <u>Insurance fund injection skipped on insolvent liquidations/ADL — <code>_maybeInjectInsurancePool</code> sits after all <code>handleEarlyReturn</code> exits, so reserves are not deployed during the bad-debt events they cover</u>	Resolved
	ZEROMARK-149 <u>Dynamic MMR maintenance requirement is structurally below the liquidation fee → systematic LP loss on liquidations (insurance fund unfunded)</u>	Resolved
	ZEROMARK-154 <u>PythHermesFeedProvider performs no signature verification and mis-scales every price by $10^{\text{tokenDecimals}}$ — unsafe to enable (PythHermesFeedProvider)</u>	Resolved
	ZEROMARK-192 <u>PythLazerFeedProvider ignores signed exponent → WTI 100x oracle mispricing (no ref backstop)</u>	Resolved
	ZEROMARK-264 <u>Combined pro and affiliate discounts can block liquidation</u>	Resolved
	ZEROMARK-273 <u>Insurance checks temporarily double-count realized borrowing fees</u>	Resolved
	ZEROMARK-386 <u>Unsigned Pyth Hermes data is trusted as an oracle price</u>	Resolved
	ZEROMARK-588 <u>Baseline swap funding uses receiver-side open interest, causing payer-side overcharge and claimable funding over-accrual</u>	Resolved
	ZEROMARK-655 <u>Fork dropped the upstream subaccount fee-swap size cap: a count-authorized subaccount can grief the main account via an uncapped relay fee-swap (0.5% atomic fee/action); attacker profit zero</u>	Resolved



ZEROMARK-831

Deposits, shifts, normal orders, and GLV executions bypass the sequencer grace gate

Resolved



ZEROMARK-1156

claimCollateral drops GMX's CLAIMABLE_COLLATERAL_DELAY backstop: withheld claimable collateral is permanently unrecoverable if the keeper never sets the claimable factor

Resolved

• LOW



ZEROMARK-38

`Config.setBaselineSwap()` is permanently unusable because the external setter and its internal helper both use `nonReentrant`

Resolved



ZEROMARK-130

First-deposit cancellation sends the unused execution-fee refund to address(1) instead of the depositor

Resolved



ZEROMARK-152

Single-token market pool caps are enforced against half the raw pool, allowing about 2x the configured exposure

Resolved



ZEROMARK-325

USD0 Markets Missing `singleTokenMarketConfig` allows Non-Zero Swap Fees Charged on Deposits/Withdrawals

Resolved



ZEROMARK-499

Deposit swap paths can mutate a market before checkpointing borrowing, letting stale borrowers keep fees owed to LPs

Resolved



ZEROMARK-557

Balanced Markets Can Still Charge One-Sided Minimum Funding

Resolved



ZEROMARK-591

InsuranceFundUtils.topUp() is declared internal with no production callers — insurance reserves cannot be replenished by governance

Resolved



ZEROMARK-623

Zero-fee liquidation callbacks let traders externalize callback gas into forced closes

Resolved



ZEROMARK-794

Division-by-Zero via Zero Leverage Tier in LeverageLadderUtils

Resolved



ZEROMARK-829

Borrowing-fee smaller-side skip compares stale stored open interest while the long side's reserve usage is priced live, so the larger-reserve side is exempted after a price move

Resolved



ZEROMARK-833

Relay fee accounting can assign stray router WNT to the next gasless caller

Resolved



ZEROMARK-934

Atomic withdrawals are incorrectly blocked by the normal withdrawal feature flag

Resolved

	ZEROMARK-978 <u>Pyth Lazer zero-confidence update halts pricing</u>	Resolved
	ZEROMARK-1052 <u>Reducing `MAX_AUTO_CANCEL_ORDERS` can hide auto-cancel orders from full-close cleanup, leaving stale orders executable against future positions</u>	Resolved
	ZEROMARK-1164 <u>Paginated set readers revert with an arithmetic underflow on stale / out-of-range cursors</u>	Resolved

• NONE

	ZEROMARK-418 <u>Atomic withdrawals can overpay LP exits using stale Chainlink prices while current oracle prices are rejected</u>	Informative
	ZEROMARK-569 <u>Last-withdrawal pool fees can be captured by the next OxMarkets market-token depositor after supply resets to zero</u>	Informative
	ZEROMARK-238 <u>Insolvent liquidation lets liquidated account withdraw pool-backed USDC while poolAmount remains unchanged</u>	Informative
	ZEROMARK-183 <u>MarketDecrease oracle anchor omits positionIncreasedAtTime, letting a stale signed price close a freshly opened position at a guaranteed profit.</u>	Informative
	ZEROMARK-1145 <u>Asymmetry between capped PnL pool deduction and uncapped OI reduction allows traders to bypass the positive-PnL cap via partial closes, draining excess value from LPs</u>	Informative

ABOUT PROJECT

OxMarkets is a decentralized perpetual protocol for trading crypto, forex, and real-world assets (RWA) on-chain.

DISCLAIMER

HackenProof Disclaimer

The application provided for assessment has been analyzed in accordance with generally accepted industry practices applicable at the time this report was prepared. The assessment focused on identifying cybersecurity vulnerabilities and security issues in the application's

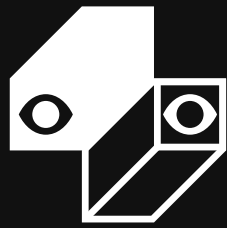
source code, deployment, configuration, and functionality, based solely on the materials, access, and scope made available for the engagement.

This report does not provide any representation or warranty that all vulnerabilities, weaknesses, or misconfigurations have been identified, nor does it guarantee the absolute security, reliability, or bug-free status of the application. The conclusions herein apply only to the specific version and scope reviewed and may no longer remain valid after any modification, update, or environmental change. This report should not be regarded as a definitive or exhaustive statement of the application's security posture.

Technical Disclaimer

Applications, whether decentralized applications (DApps) or other software systems, are deployed and operated within technical environments that may include blockchains, cloud services, operating systems, programming languages, frameworks, libraries, APIs, third-party services, and infrastructure components. Any of these elements may contain inherent weaknesses, undisclosed vulnerabilities, or configuration issues that can result in security incidents, operational failures, or unauthorized access.

The assessment reflects the condition of the application only at the time of testing and within the agreed scope, and the absence of findings in this report must not be interpreted as evidence that no vulnerabilities exist. Continuous security practices, including secure development, independent reviews, monitoring, patch management, and periodic reassessments, remain necessary to maintain an appropriate level of security.



HackenProof

Expert crowdsourced security provider

AUDIT CONTEST

Contact us:



[LinkedIn](#)



[X](#)



[Website](#)



[Mail](#)